

GROUP ACTIVITY • WORKSHOP

Applied Cybersecurity Workshop

Secure Architecture & Incident Response

This workshop combines Lesson 1 (Mitigation Techniques & Vulnerability Response) and Lesson 2 (Architecture Models & Their Security Implications). Each group takes on the role of a fictional company's security team — first designing its architecture, then responding to a vulnerability discovered inside it.

Workshop Objectives

This activity asks each group to act as the security team for a fictional company facing a real infrastructure decision. It has two connected parts: first design (or evaluate) the company's architecture, then respond to a vulnerability discovered within that architecture. Completing both parts well requires drawing on concepts from both lessons.

From Lesson 1 — Mitigation Techniques & Vulnerability Response

- Apply enterprise-level mitigation strategies
- Use risk-based thinking to prioritize vulnerability fixes
- Explain and follow a structured vulnerability handling process
- Understand documentation, escalation, and communication protocols

From Lesson 2 — Architecture Models & Their Security Implications

- Identify and compare key architecture models (on-prem, cloud, hybrid, edge)
- Explain the implications of zero trust vs. perimeter-based design
- Understand how virtualization and containers impact security architecture
- Evaluate the trade-offs in security design decisions
- Compare cloud service models and associated risks

How the Workshop Works

Every scenario is split into two parts. Part A asks your group to make architecture and security-model decisions for the company — the Lesson 2 concepts. Part B introduces a vulnerability discovered inside the very architecture your group just designed, and asks you to triage and respond to it — the Lesson 1 concepts. Choices from Part A should carry forward into Part B: the architecture you chose shapes how you'll mitigate and who you'll need to notify.

Suggested Team Roles

Assign one role per team member. In groups of three, combine the last two roles.

Role	Primary Focus
Architecture Lead	Drives the architecture model, security model, and cloud service model decisions in Part A
Risk & Prioritization Analyst	Leads the vulnerability triage and prioritization work in Part B
Incident Commander	Owens the mitigation plan and walks the team through the vulnerability handling lifecycle

Role	Primary Focus
Documentation & Communications Lead	Drafts the written brief, plans the escalation/notification list, and coordinates the presentation

SCENARIO 1

MedLink Telehealth

Industry	Telehealth / digital health
Size	40 employees, 18 months old
Current Setup	On-premise servers hosting the patient portal and video-consultation platform
Regulatory Context	Handles Protected Health Information (PHI); subject to HIPAA
Growth Situation	Just signed contracts to expand into 12 new states; care providers now work from home offices and satellite clinics across the country
Constraints	Small IT team (2 people); limited budget; investors expect national scale within 6 months

Part A — Secure the Architecture

MedLink's leadership has asked your team to redesign their infrastructure and security approach ahead of the national expansion. As the security team, address the following:

1. Recommend an architecture model (on-prem, cloud, hybrid, or edge) for MedLink and justify your choice against their growth plans, budget, and regulatory context.
2. Recommend a security model — zero trust or perimeter-based — for how remote care providers and satellite clinics will access patient data. Justify your choice.
3. If your architecture involves cloud services, choose a cloud service model (IaaS, PaaS, and/or SaaS) for at least two components of their system (e.g., patient portal, video platform, internal tools) and map out the shared responsibility split.
4. MedLink is considering breaking their monolithic patient portal into containerized microservices to speed up development. Identify at least one security advantage and one security concern with this move.
5. Identify at least two trade-offs your team accepted in this design (e.g., performance vs. control, scalability vs. security) and explain how you'll manage the risk.

Part B — Respond to the Incident

THE SITUATION

Three weeks after your new architecture goes live, MedLink's security monitoring flags an advisory: a critical vulnerability (CVSS 8.1) has been disclosed in the authentication library used by the video-consultation platform. Exploit code has already been published publicly. The vendor has confirmed the issue but has no patch available yet.

1. Using the three risk-based prioritization factors, explain how you would prioritize this vulnerability given MedLink's context.
2. Propose at least two mitigation actions your team would take while waiting for a patch.
3. Walk through how this incident would move through the five-stage vulnerability handling lifecycle at MedLink, briefly describing what happens at each stage.
4. Given that PHI is involved, identify who should be notified and why, referencing the tiered notification model.

Deliverable: Architecture & Incident Response Brief

Each group submits one written brief (2–4 pages is plenty) using the structure below. Bullet points are fine — this is a working document, not a formal report.

1. Company Snapshot

2–3 sentences summarizing the company and the challenge it's facing.

2. Architecture Decision

Model chosen (on-prem / cloud / hybrid / edge) and justification.

3. Security Model Decision

Zero trust or perimeter-based, and justification.

4. Cloud Service Model & Shared Responsibility

If applicable — which model(s) chosen and the responsibility split.

5. Virtualization / Container Considerations

Isolation or image-security concerns identified, and how you'd address them.

6. Trade-offs Identified

At least two, each with a concrete way you'll manage the risk.

7. Vulnerability Triage

How you prioritized the incident using CVSS, asset criticality, and exploitability together.

8. Mitigation Plan

At least two immediate actions taken while a permanent fix is pending.

9. Vulnerability Lifecycle Walkthrough

One to two sentences per stage: Discovery, Triage, Response, Remediation, Recovery & Review.

10. Documentation & Escalation Plan

Who is notified, in what order, and why.

11. Lessons Learned (optional)

2–3 sentences reflecting on what your team would do differently.

Grading Rubric

Criterion	Points	What We're Looking For
Architecture Model Justification	15	Choice fits company context (size, regulation, growth); reasoning references trade-offs, not just preference
Zero Trust vs. Perimeter Reasoning	15	Correctly applies core principles; justification fits the scenario's user/device distribution
Virtualization & Container Considerations	10	Identifies a real isolation or image-security concern relevant to the scenario
Trade-off Analysis	10	At least two distinct trade-offs identified, each with a concrete risk-management step
Cloud Service Model & Shared Responsibility	10	Correct mapping of responsibility across the chosen service model(s)
Risk-Based Triage	10	Uses CVSS, asset criticality, and exploitability together — not CVSS alone
Mitigation Strategy	10	At least two concrete, scenario-appropriate mitigation actions
Vulnerability Lifecycle Walkthrough	10	All five stages addressed with scenario-specific detail
Documentation & Escalation Plan	5	Notification list matches the sensitivity and context of the scenario
Team Collaboration & Presentation	5	Every member contributes to both the brief and the presentation
Total	100 (4)	Scale (0-4) 0-24=0, 25-59=2, 60-74=3, 75 > = 4